CYPHER GROUP INC. · SIMULATED CASE STUDY

CGI-AIG-001 — AI Governance Assessment

Cypher Group Inc. · Version 1.0 · 17 October 2026

> **Simulated case study.** Cypher Group Inc. and its suppliers are simulated. The laws, standards, articles and clause numbers are real and current to 17 October 2026; ISO/IEC 42001 wording is paraphrased.

Field	Value
Document ID	**CGI-AIG-001**
Version	1.0
Status	Draft for approval
Assessment date	17 October 2026
Prepared by	O.S — assessor
Approving authority	Jerry Gold, Chief Executive Officer
Laws and standards	**EU AI Act**, Regulation (EU) 2024/1689 as amended by the **Digital Omnibus on AI**, Regulation (EU) 2026/1744 · **ISO/IEC 42001:2023** · **NIST AI RMF 1.0** · GDPR, Regulation (EU) 2016/679
Mapped to	ISO/IEC 27001:2022 Annex A · SOC 2 Trust Services Criteria · NIST CSF 2.0 · CGI-RSK-001 risk IDs
Inputs consumed	CGI-POL-001 §4.5 · CGI-RSK-001 v1.2 (14 risks) · CGI-GAP-001 (1.32) · CGI-TPR-001 (T2-f, questionnaire domain 15, CGI-VEN-012 and -013, VRA-2026-002 F-004) · CGI-ISO-001 (clause method, 93-control SoA) · CGI-SOC-001 / CGI-IAU-001 · CGI-AWS-001 (no AI service in the CloudCo accounts)
Nature of the work	Documentation-based assessment of how Cypher governs the AI it uses. Not legal advice.
Next review	AI register quarterly (AIG-14); full reassessment by 31 Mar 2027

Headline result. Cypher uses **three AI systems**, all bought from suppliers, and plans a fourth of its own (scenario **AI-A01**).

- **None is high-risk under the EU AI Act, and none is a prohibited practice.** Article 6 and Annex III decide that for each system. Cypher's AI Act duties today are **Article 4 (AI literacy)** and **Article 5 (do not use banned practices)**. The planned product assistant would add **Article 50** transparency duties at launch.
- **The real problem is not a dangerous model. It is AI that arrived on expense claims.** ScribeCo records customer calls under **no contract of any kind**, and its decision date passed two days ago. ChatCo's AI reads customer posts under no training ban. The approved AI tools list the policy depends on does not exist.
- **ISO/IEC 42001 readiness is 30.3%** (18/60 on clauses; 26 of 38 Annex A controls apply, none implemented). All 9 gate requirements fail.
- **Two new risks** pass the drawer-2 test and enter **CGI-RSK-001 v1.3**: AR-001 (wrong AI output acted on) and AR-002 (a tool used for a banned or high-risk purpose). Residual total **130 → 147** across 16 risks.

The decision:

- **GO** today on suspending ScribeCo from calls, and on evidencing that ChatCo's AI is off. Both cost nothing.
- **NO-GO** on ISO/IEC 42001 certification before the ISO 27001 certificate (November 2027). Build one joint management system instead.

No maturity score moves (1.32). An inventory and an assessment measure the gap; they do not close it.

Contents

- Part 1 — The Why
- Part 2 — AI system inventory and AI register
- Part 3 — EU AI Act applicability
- Part 4 — ISO/IEC 42001 readiness and Statement of Applicability
- Part 5 — Two AI impact assessments
- Part 6 — Multi-framework mapping
- Part 7 — Findings register
- Part 8 — Risk register: CGI-RSK-001 v1.3
- Part 9 — Remediation roadmap and reconciliation
- Part 10 — Effect on maturity
- Part 11 — One-page executive summary
- Appendix A — Verification, assumptions and limitations
- Appendix B — Glossary

Part 1 — The Why

1.1 AI governance is not information security with a new name

An AI system **infers** its output. Nobody wrote its mistakes line by line, so a perfectly secured system can still give a confident, wrong answer that someone acts on.

	Information security (Projects 01–07)	AI governance (this project)
Protects	The information: confidentiality, integrity, availability	The **people affected by the output**, and the information
A failure looks like	A leak, an outage, a tampered record	A wrong summary sent to a customer · customer content training someone else's model · a banned use of an approved tool
Key question	Who can get to the data?	What does the system do with it, and who answers for what it says?
EU law	GDPR, NIS2	**EU AI Act** + GDPR
Certifiable standard	ISO/IEC 27001	**ISO/IEC 42001**
NIST framework	CSF 2.0	**AI RMF 1.0**

Plain-English picture. Information security locks the kitchen. AI governance writes the rules for the robot cook: what it may cook, which ingredients it may take home, who tastes before serving, and who answers if a guest gets sick.

1.2 The EU AI Act in one page

Regulation (EU) 2024/1689 applies directly in every EU country. The **Digital Omnibus on AI** (Regulation (EU) 2026/1744) amended it; it was published on 24 July 2026 and has been in force since 27 July 2026.

The ladder. Regulation → Chapter (13) → Section (only some chapters) → Article (about 113) → paragraph → point. **Article 26(2)** is Article 26, paragraph 2. Annexes sit beside the ladder: an Article points to them (Article 6(2) points to Annex III). **Risk tier and role are labels, not rungs.** The tier is worn by the system; the role is worn by the company.

Tier	What it means	Deciding article
Prohibited	Banned: eight practices since 2 Feb 2025, including **emotion recognition at work**, plus two more from 2 Dec 2026	Art. 5
High-risk	Heavy duties. Annex I route: AI in regulated products. Annex III route: eight areas, including **employment**	Art. 6(1) / 6(2), Art. 6(3) exception
Transparency	Tell people about AI interaction, generated content and deepfakes. **Each duty names its role**	Art. 50
Minimal	Everything else	—

Role	Plain English	Article
Provider	Builds it, or has it built, and puts it out under its own name	Art. 3(3)
Deployer	Uses it under its own authority at work	Art. 3(4)
Importer / distributor	Brings it into, or passes it along, the EU supply chain	Art. 3(6) / 3(7)

A deployer can become a provider (Art. 25): by putting its name on a high-risk system, modifying one substantially, or **using a non-high-risk system for a high-risk purpose** (Art. 25(1)(c)). That last route is the one a small company walks into without noticing.

1.3 General-purpose AI and AI literacy

- A **general-purpose AI model** (Art. 3(63)) is the engine behind tools like ScribeCo. Its maker carries the **Chapter V** duties (since 2 Aug 2025). Cypher trains no model, so Chapter V does not reach it.
- **Article 4** has applied since 2 Feb 2025. On 27 Jul 2026 the Omnibus rewrote it: providers and deployers must **take measures to support** the AI literacy of their staff, and the text now says no specific level has to be guaranteed. **An obligation of effort, not of result** — but the measures must be evidenced.

1.4 ISO/IEC 42001 — the AI management system

ISO/IEC 42001:2023 is the certifiable standard for an **AI management system (AIMS)**. It shares ISO's **Harmonized Structure** with ISO/IEC 27001, so clauses 4–10 line up, and one internal audit, one management review and one corrective-action log can serve both. What it adds: an **AI policy**, AI risk criteria that include **harm to people**, and an **AI system impact assessment** (clause 6.1.4).

Annex A: 38 controls in 9 groups (A.2 to A.10). Standard → Annex A group (A.6) → [objective, only in A.6: A.6.1, A.6.2] → control (A.6.2.4). No control number ends in .1.

> **Watch the number clash.** "A.5" in **ISO/IEC 27001** is a theme of 37 organisational controls. "A.5" in **ISO/IEC 42001** is a group of 4 impact-assessment controls. Always say the standard first.

1.5 NIST AI RMF

A voluntary framework (NIST, January 2023) with four functions: **GOVERN, MAP, MEASURE, MANAGE**, written in words (GOVERN 1.1). Do not confuse it with CSF 2.0, whose **GV** codes (GV.RM-01) belong to Project 03.

1.6 Three assessments that get confused

	DPIA	AI system impact assessment	FRIA
Source	GDPR Art. 35	ISO/IEC 42001 6.1.4 and A.5	AI Act Art. 27
Looks at	Risks from processing **personal data**	Any harm from the system's **outputs and use**, to individuals, groups or society	Fundamental rights affected by a **high-risk** system
Cypher?	Required for three tools (Part 5.4)	Two performed here	Not required: no high-risk system, and Cypher is not a listed deployer type

A DPIA asks what happens to the ingredients. An AI impact assessment asks what happens to the guests. A summary that misstates a customer's commitment harms them with no personal-data breach at all.

1.7 Training on customer data, human oversight and shadow AI

- **Training on customer data.** Once content shapes a model it cannot be recalled. Cypher is a processor for its customers, so it may not let a supplier use their content for a purpose the customers never authorised. CGI-TPR-001 asks this as **VQ-68** (weight 5) and accepts only a **contractual prohibition or signed confirmation**. A settings toggle is not enough.
- **Human oversight.** A person who checks the output **before** it is used lowers the likelihood of harm. Articles 14 and 26 make oversight a legal duty only for high-risk systems; for Cypher it is a policy rule (CGI-POL-001 §4.5.3). **Automation bias** is the reason it needs a record: a reviewer approving forty summaries an hour is a rubber stamp.
- **Shadow AI** is AI used without approval. In a 50-person company the realistic AI risk is not a rogue model; it is an employee with a credit card.

1.8 How drawer 8 completes the programme

Projects 01 to 07 protect what Cypher stores. Project 08 governs what a machine says and decides.

Project	What it left open	What this assessment does with it
01	CGI-POL-001 §4.5: AI rules approved, bypassed by ScribeCo	Seed of the AI policy, referenced not rewritten (AIG-07)
02	VR-005, VR-006, R-003; register v1.2 (213 / 130)	Drawer-2 test before any new risk; v1.3 totals (Part 8)
03	GV.OC 1, GV.PO 2, ID.AM 1, PR.AT 1; overall 1.32	Says what moves and why nothing does (Part 10)
04	T2-f, questionnaire domain 15, ScribeCo, WriteCo, ChatCo F-004	The **only** source of the AI inventory (Part 2)
05	Clause method, SoA, A.5.8 / A.5.10 / A.8.12 citing AI tools	Same scoring method; joint management system (Part 4.5)
06	No criterion counterpart for A.5.31 and the clause requirements	"None" stated honestly in the mapping (Part 6)
07	No AI service in the CloudCo accounts	Confirms Cypher builds no AI today, so it is a deployer

Part 2 — AI system inventory and AI register

2.1 How the inventory was built

> **Build narration.** I did not ask people which AI tools they use; that finds only the tools people remember. Every row comes from something an earlier project already recorded: the supplier inventory (CGI-TPR-001), its AI tiering trigger T2-f, the ChatCo assessment (VRA-2026-002) and the cloud review (CGI-AWS-001). **Nothing appears here that an earlier project did not record**, and no evidence is assumed that an earlier project records as missing. Where the record runs out, an assumption is declared (AI-A01 to AI-A04) and a verification action is scheduled.

Source	What it gave
CGI-TPR-001 inventory (finance discovery)	ScribeCo and WriteCo, both bought on expenses
CGI-TPR-001 VRA-2026-002, finding F-004	ChatCo's AI features reading message content
CGI-TPR-001 trigger T2-f	Proof the tiering rule fired: WriteCo moved from Tier 3 to Tier 2
CGI-AWS-001	No AI service in any CloudCo account: Cypher builds no AI today
CGI-POL-001 §4.5	The rules the tools should have followed

2.2 The AI register

ID	AI system	Supplier	Status on 17 Oct 2026	Business owner	Cypher's role	Tier for Cypher	Deciding article(s)	Training on Cypher content (VQ-68)	Art. 28 DPA
AIS-01	ScribeCo meeting assistant	ScribeCo (CGI-VEN-012)	In use. Shadow AI found 15 Sep 2026 in the expense review; CGI-TPR-001 decision was due 15 Oct 2026 and none is recorded	Head of Customer Success	Deployer	Minimal (no AI Act duty beyond Art. 4 and Art. 5)	Art. 6(2) + Annex III (no listed use); Art. 5(1)(f) checked (see AI-A02); Art. 50(3)-(4) not triggered	Unknown: no contract, terms never reviewed	None: no contract of any kind
AIS-02	ChatCo AI features	ChatCo (CGI-VEN-004)	Recorded as processing message content (VRA-2026-002 F-004, 15 Sep 2026). Action R4 (switch off by 01 Oct 2026) has no completion evidence, so treated as on (AI-A04)	IT Operations Manager	Deployer	Minimal (no AI Act duty beyond Art. 4 and Art. 5)	Art. 6(2) + Annex III (no listed use); Art. 50(3)-(4) not triggered	Not Met: training not contractually prohibited; human review not excluded (F-004, VQ-68 and VQ-69)	Not executed (F-001)
AIS-03	WriteCo writing assistant	WriteCo (CGI-VEN-013)	In use on 12 seats. Assessed Pass with conditions (extension scope restricted); Tier 2 by trigger T2-f	Head of People and Operations	Deployer	Minimal (no AI Act duty beyond Art. 4 and Art. 5)	Art. 6(2) + Annex III (no listed use); Art. 25(1)(c) watch: an HR use could make Cypher a provider	Not evidenced: individual licences, no executed terms	None: individual licences on expense
AIS-04	AI-A01 project assistant (scenario)	ModelCo, a general-purpose model provider (scenario; not counted in CGI-TPR-001)	Scenario assumption AI-A01: design gate 31 Mar 2027, planned launch 01 Sep 2027. Not live; excluded from every earlier project's numbers	Chief Technology Officer	Provider (and downstream provider)	Transparency (Art. 50) at launch; not high-risk while the intended purpose excludes judging workers	Art. 50(1) and 50(2); Art. 6(2) + Annex III point 4(b) excluded by the intended-purpose statement	Design requirement: zero retention and no training, by contract	Required before build: ModelCo DPA; customer sub-processor notice

Data flows and oversight

ID	Data in	Data out	People affected	Human oversight today	Related risks
AIS-01	Full audio of internal and customer calls: voices, names, commercial and security discussion, any personal data spoken aloud	Transcripts, summaries, action items	Customer staff on calls; Cypher staff; third parties named in calls	None recorded. CGI-POL-001 s4.5.3 requires review before output reaches a customer	VR-005; VR-006; VR-001; R-003; AR-001
AIS-02	Message content, pasted credentials and screenshots, incident traffic, customers' posts in shared channels	AI answers and channel summaries inside ChatCo (internal)	Cypher staff; customer staff posting in shared channels	None recorded for AI output	VR-006; VR-001; R-003
AIS-03	Any text typed into a web field: ChatCo, WikiCo, the CGI admin console, email	Suggested and drafted text that staff send onwards	Cypher staff; recipients of drafted text, including customers	Author edits before sending (by design, not recorded)	VR-006; VR-005; VR-001; R-003; AR-001
AIS-04	Customer project content; users' prompts	Generated answers and summaries shown to customer users	Customer users; their team members named in projects	Design requirement: user reviews before sharing; feedback and stop control	R-004; AR-002; VR-006

2.3 Scenario AI-A01 — testing the provider role

Cypher builds no AI today, so a deployer-only assessment would never test the provider side of the Act. **AI-A01** is a declared scenario: an in-product assistant that answers customers' questions about their own projects, built on a general-purpose model from a supplier called **ModelCo**. Design gate 31 Mar 2027, launch planned 01 Sep 2027. **It is excluded from every earlier project's numbers**: ModelCo is not supplier 18, and no risk score, maturity score or SoA status uses it.

2.4 Assumptions the register depends on

ID	Assumption	Why it matters
AI-A01	Cypher plans an in-product AI project assistant built on a third-party general-purpose model (ModelCo). Design gate 31 Mar 2027; launch not before 01 Sep 2027.	Tests the provider role. Declared after 16 Oct 2026 and kept out of every earlier project's numbers: ModelCo is not supplier 18, and no risk score, maturity score or SoA status uses it.
AI-A02	ScribeCo is used for transcription and summaries only. No feature infers emotions from voice and no output is used to assess staff.	Unverified (no contract, no product review). If either is false, Art. 5(1)(f) or Annex III point 4(b) applies. Verified through AIG-04.
AI-A03	No supplier AI feature is used for recruitment, staff evaluation, credit or other Annex III purposes.	Rests on what earlier projects record. HRCo, SupportCo, CRMCo and OfficeCo have no recorded VQ-67 answer. Verified through AIG-04 (finding AF-04).
AI-A04	ChatCo's AI features are still switched on.	VRA-2026-002 action R4 was due 01 Oct 2026 and no later deliverable records it done. Never assume evidence an earlier

ID	Assumption	Why it matters
		project records as absent.

Part 3 — EU AI Act applicability

3.1 Method: eight questions, in order, each with its article

1. Is it an AI system? (Art. 3(1))
2. What is Cypher's role? (Art. 3; Art. 25)
3. Is it a prohibited practice? (Art. 5)
4. Is it, or is it part of, an Annex I product? (Art. 6(1))
5. Is it used in an Annex III area? (Art. 6(2))
6. If so, does the Art. 6(3) exception apply?
7. Does an Art. 50 transparency duty fall on **Cypher**, or on the provider?
8. Does Cypher provide a general-purpose AI **model**? (Chapter V)

3.2 Results

ID	System	Cypher's role	Prohibited? (Art. 5)	Annex III use? (Art. 6(2))	Art. 50 duty on Cypher?	Tier for Cypher	Applies today	What would change it
AIS-01	ScribeCo meeting assistant	Deployer. Not provider: no own name, no modification, no change of purpose	No, subject to AI-A02. Emotion inference from voice at work would be Art. 5(1)(f); sentiment from transcript text alone is not emotion recognition (Art. 3(39) needs biometric data)	No: transcription is not in any of the eight Annex III areas	No: Art. 50(3) and 50(4) not triggered. Art. 50(1) and 50(2), if they apply, are ScribeCo's	Minimal	Art. 4 AI literacy measures; Art. 5 do-not-use. Outside the Act: GDPR Arts 13-14 notice, 28 contract, 35 DPIA, 44-46 transfer	Using summaries to assess staff performance (Annex III 4(b), from 2 Dec 2027, and Cypher may become provider under Art. 25(1)(c)); enabling voice emotion analysis on internal calls (prohibited now)
AIS-02	ChatCo AI features	Deployer	No	No	No: Art. 50(1) and 50(2) are ChatCo's	Minimal	Art. 4; Art. 5. Outside the Act: GDPR Art. 28 (no DPA), Art. 35 screening before re-enabling	Using chat analytics to score staff behaviour (Annex III 4(b))
AIS-03	WriteCo writing assistant	Deployer	No	No	No: Art. 50(4) applies only to AI text published to inform the public on matters of public interest, and a person edits every draft. Art. 50(2) is WriteCo's	Minimal	Art. 4; Art. 5. Outside the Act: GDPR Art. 28 (no DPA)	HR using it to rank applicants or rate staff: Annex III 4(a)/(b) from 2 Dec 2027, and Art. 25(1)(c) would make Cypher the provider of a high-risk system
AIS-04	AI-A01 project assistant (scenario)	Provider (Art. 3(3)) and downstream provider (Art. 3(68)); ModelCo is the GPAI model provider	No, by design	Not while the intended-purpose statement excludes monitoring or evaluating workers. A 'who on my team is underperforming' feature would be Annex III 4(b)	Yes, at launch: Art. 50(1) tell users they are dealing with AI; Art. 50(2) machine-readable marking of generated text	Transparency	Nothing yet (not on the market). Art. 4 from the start of development	Adding staff-performance features (high-risk, Annex III 4(b)); fine-tuning ModelCo's model at scale (GPAI model provider)

3.3 What applies today and what applies later

Dates checked on 17 October 2026 against the Act as amended by Regulation (EU) 2026/1744.

Date	What starts to apply	Article	Applies to Cypher?	How
02 Feb 2025	Prohibited practices (eight)	Art. 5	Yes	A do-not-use duty for every system. No current system does any of them (AI-A02, AI-A03).
02 Feb 2025	AI literacy (rewritten 27 Jul 2026: 'take measures to support')	Art. 4	Yes	As deployer of AIS-01 to AIS-03; as provider of AIS-04 from development. Supervised nationally since 02 Aug 2026.
02 Aug 2025	General-purpose AI model obligations; national penalty regimes	Chapter V; Art. 99	No	Cypher provides no general-purpose model. The duties sit with the model providers behind ScribeCo, ChatCo, WriteCo and ModelCo.
27 Jul 2026	Digital Omnibus on AI in force	Reg. (EU) 2026/1744	Yes	Article 4 rewritten; high-risk dates moved; small mid-cap category created.
02 Aug 2026	Transparency duties	Art. 50	Not as deployer	No Art. 50(3) or 50(4) use. As provider of AIS-04, at launch.

Date	What starts to apply	Article	Applies to Cypher?	How
02 Dec 2026	Two new prohibitions (non-consensual intimate content; child sexual abuse material)	Art. 5(1)(ba), (bb)	Yes (do-not-use)	No current system generates images or video.
02 Dec 2026	Marking deadline for generative systems on the market before 02 Aug 2026	Art. 111(4)	No	A provider duty. Affects ScribeCo, ChatCo and WriteCo, not Cypher.
02 Dec 2027	High-risk rules, Annex III route	Art. 113, as amended	No today	Only if an Annex III use begins (AR-002). The census AIG-04 confirms none exists.
02 Aug 2028	High-risk rules, Annex I route	Art. 113, as amended	No	Cypher makes no product covered by Annex I.

3.4 The plain statement

Cypher has no high-risk AI system and uses no prohibited practice. For each system, Article 6 with Annex III decides it is not high-risk, and Article 5 was checked against what earlier projects record.

What would change that:

- **Using any AI to rank job applicants or judge staff performance** (Annex III, point 4). Through Art. 25(1)(c), doing this with a general tool such as WriteCo would also make Cypher the **provider** of a high-risk system. High-risk duties for Annex III apply from 2 Dec 2027.
- **Switching on emotion inference from voices on internal calls.** That is prohibited now (Art. 5(1)(f)), not later. Sentiment read from text alone is not emotion recognition, because the definition needs biometric data.
- **A supplier feature nobody has declared.** The statement holds for the four recorded systems; the census AIG-04 makes it company-wide (limitation L-03).

> **Build narration.** I separated "the system's tier" from "Cypher's duties" on purpose. Article 50 can apply to ScribeCo's product without placing any duty on Cypher, because every Article 50 duty names a role. Treating ScribeCo as "transparency tier" for Cypher would invent a duty Cypher does not have, and miss the duty it does have: telling people on calls under **GDPR Articles 13 and 14**.

3.5 AI-A01: the provider test

As provider, Cypher would owe **Art. 50(1)** (tell users they are dealing with AI, unless obvious) and **Art. 50(2)** (mark generated text in a machine-readable way) at launch, plus Art. 4 from the start of development. The assistant stays **out of high-risk only if its intended-purpose statement excludes judging workers**. In a project-management product, a "who on my team is underperforming?" prompt is the most likely way to drift into Annex III point 4(b). So the intended purpose is written first, and the design gate (AIG-13) checks against it.

Part 4 — ISO/IEC 42001 readiness and Statement of Applicability

4.1 Draft AIMS scope (for approval at AIG-07)

> The AI management system of Cypher Group Inc. covers the selection, deployment and use of third-party AI systems by all functions, and the AI-related obligations Cypher owes its customers and staff. Cypher's role is **AI customer and user (deployer)**. Development of AI systems is outside the scope until the AI-A01 design gate, when Annex A groups A.6 and A.7 come into scope.

4.2 Clauses 4–10

Method (CGI-ISO-001, unchanged): 0 = absent · 1 = partly in place, or designed but not evidenced · 2 = met, with evidence. **Gate** marks requirements whose absence stops a Stage 1 audit whatever the score. The CGI-ISO-001 gates are reused, plus **6.1.4** (impact assessment), because it is the requirement that makes 42001 different.

Clause	Requirement (paraphrased)	Gate	Score	Current state	Gap	27001 evidence reusable	Action	Due
4.1	Understand the organisation's context for AI, including its role for each AI system and the intended purpose of the systems it uses or provides	N	1	Roles and purposes drafted in this document (Part 2); AI vendors identified by CGI-TPR-001 T2-f.	Not approved; no context statement for AI.	Partial: extend the ISO-01 context and issues statement	AIG-07; ISO-01	31 Dec 2026
4.2	Interested parties and their AI-related requirements, including legal ones	N	1	Customers on calls and in shared channels, staff and the GDPR authority are known from CGI-TPR-001 and CGI-POL-005.	AI Act and GDPR AI duties are in no obligations register.	Yes: the ISO-01 interested-parties and obligations register (A.5.31)	AIG-11; ISO-01	30 Jun 2027
4.3	Decide and document the scope of the AI management system	Y	1	Drafted in Part 4.1 of this document.	Not approved.	Partial: same format as the ISO-02 ISMS scope	AIG-07	31 Dec 2026

Clause	Requirement (paraphrased)	Gate	Score	Current state	Gap	27001 evidence reusable	Action	Due
4.4	Establish, run, maintain and improve the AI management system	N	1	Pieces exist: CGI-POL-001 s4.5, tiering trigger T2-f, questionnaire domain 15.	They do not run as one system; AI tools bypassed them.	Yes: fold into the ISO-08 ISMS overview	AIG-11	30 Jun 2027
5.1	Top management shows leadership and commitment to the AIMS	N	1	The CEO approved CGI-POL-001 (including s4.5) and CGI-TPR-001 (including T2-f).	No stated commitment or resources for AI governance.	Partial: same sign-off route as ISO-03	AIG-07	31 Dec 2026
5.2	An AI policy that fits the organisation, sets a framework for AI objectives and commits to meeting requirements and improving	N	1	CGI-POL-001 s4.5: four clauses on staff use of AI tools.	A clause is not a capability: s4.5 covers staff tool use only, not objectives, impact assessment, oversight or prohibited uses.	Partial: reuse the ISO-03 policy template	AIG-07	31 Dec 2026
5.3	Roles, responsibilities and authorities for the AIMS assigned and communicated	N	1	The CTO keeps the approved AI tools list and assesses requests (CGI-POL-001 s4.5.1, s4.5.4).	No AI governance lead, no impact-assessment or oversight roles.	Yes: extend the ISO-04 RACI	AIG-07; ISO-04	31 Dec 2026
6.1.1	Determine the AIMS's own risks and opportunities and plan actions	N	0	None.	Not considered.	Yes: same record as ISO-08 (6.1.1)	AIG-11	30 Jun 2027
6.1.2	An AI risk assessment process with criteria that cover harm to people, not only to the organisation	Y	1	CGI-RSK-001 applies NIST SP 800-30 and has scored AI risks (VR-005, VR-006, and AR-001/AR-002 here).	No acceptance criteria (GAP-002) and no harm-to-people criteria.	Partial: extend ISO-05	AIG-11; ISO-05	30 Jun 2027
6.1.3	AI risk treatment: choose controls, compare with Annex A, produce a Statement of Applicability, get owners' approval	Y	1	SoA drafted in Part 4.2 (38 controls).	Not approved; treatment plans TP-11 and TP-12 proposed only.	Partial: one combined SoA approval at ISO-06	AIG-11; ISO-06	30 Jun 2027
6.1.4	An AI system impact assessment process covering effects on individuals, groups and society	Y	1	Process and two assessments drafted in Part 5.	Not approved; no trigger rule in the onboarding workflow.	No: AI-specific	AIG-05; AIG-07	31 Dec 2026
6.2	Measurable AI objectives and plans to achieve them	N	0	None.	No AI objectives.	Partial: add to the ISO-07 objectives plan	AIG-11; ISO-07	30 Jun 2027
6.3	Plan changes to the AIMS	N	0	None.	No change-planning rule.	Yes: ISO-08 procedure covers both	AIG-11	30 Jun 2027
7.1	Provide the resources the AIMS needs	N	0	The ISMS budget (USD 32,100, unapproved) contains nothing for AI.	No AI governance time or budget.	Partial: add a line to ISO-03	AIG-07	31 Dec 2026
7.2	Competence of people whose work affects AI performance, with evidence	N	0	None on file.	No AI competence requirements.	Yes: the ISO-10 matrix	AIG-11; ISO-10	31 Mar 2027
7.3	Awareness of the AI policy, one's contribution and the consequences of not conforming	N	1	CGI-POL-001 (with s4.5) acknowledged by 60% of staff.	No AI module (OFI-04); 40% not reached.	Yes: REC-09 curriculum	AIG-08	31 Dec 2026
7.4	Internal and external communication about the AIMS	N	0	None for AI. Customers on calls are not told about transcription.	No AI communication plan.	Partial: ISO-08 plan	AIG-06	30 Nov 2026
7.5	Create, update and control documented information	N	1	Every CGI document carries a control block (version, owner, review date).	No AIMS record list.	Yes: as is	AIG-11	30 Jun 2027
8.1	Plan and control the operational processes, including externally provided AI	N	1	The CGI-TPR-001 workflow controls AI suppliers by design (T2-f, Gate B).	Two of three AI tools reached use outside it.	Yes: the CGI-TPR-001 workflow	AIG-03	31 Oct 2026
8.2	Perform AI risk assessments at planned intervals and on change	N	1	VR-005 and VR-006 assessed Sep 2026; AR-001 and AR-002 assessed here.	No AI risk criteria, so not yet to the 6.1.2 method.	Partial: ISO-05 cadence	AIG-11	30 Jun 2027
8.3	Implement the AI risk treatment plan	N	1	T2-f operated: it moved WriteCo to Tier 2 and an assessment followed.	ScribeCo untreated; ChatCo action R4 unevidenced.	Partial	AIG-01; AIG-02	24 Oct 2026
8.4	Perform AI system impact assessments at planned intervals and on change	N	1	Two assessments performed in this document for two of three systems in use.	Not approved by owners; no interval set.	No: AI-specific	AIG-05	30 Nov 2026
9.1	Monitor, measure, analyse and evaluate the AIMS	N	1	KRI-V4 counts suppliers found outside onboarding each quarter.	No AI-specific measures.	Partial: ISO-07	AIG-14	31 Mar 2027
9.2.1	Internal audits at planned intervals	Y	0	None. CGI-IAU-001 WP-13 found clause 9.2 wholly unmet.	No audit of AI controls.	Yes: one programme (ISO-12)	AIG-11; ISO-12	31 May 2027
9.2.2	An internal audit programme: frequency, methods, responsibilities, reporting	Y	0	None.	No programme.	Yes: one programme (ISO-12)	AIG-11; ISO-12	31 Mar 2027
9.3.1	Top management reviews the AIMS at planned intervals	Y	0	None.	AI has never been on a leadership agenda.	Yes: one review (ISO-13)	AIG-11; ISO-13	30 Jun 2027
9.3.2	Management review inputs	Y	0	None.	No inputs defined for AI.	Yes: ISO-13	AIG-11; ISO-13	30 Jun 2027
9.3.3	Management review results	Y	0	None.	No decisions recorded.	Yes: ISO-13	AIG-11; ISO-13	30 Jun 2027
10.1	Continually improve the AIMS	N	1	Improvement happens through commissioned projects (this one included).	No routine.	Yes: ISO-08	AIG-11	30 Jun 2027
10.2	React to nonconformities and take corrective action	N	0	None. ScribeCo's breach of CGI-POL-001 s4.5 was never raised as a nonconformity.	No corrective-action record.	Yes: ISO-08 / ISO-15 log	AIG-01	24 Oct 2026
Total		9 of 9 gates fail	**18 / 60**					

4.3 Annex A — all 38 controls

Method: applicability decided first, with a reason; maturity scored on the CGI-GAP-001 0–4 scale; status **derived** from maturity, never typed (0 = Not started · 1–2 = Partial · 3–4 = Implemented). **An approved but unevidenced control is a 2, so it can never be Implemented.**

By group

Group	Name	Controls	Applicable	Not started	Partial	Implemented
A.2	Policies related to AI	3	3	0	3	0
A.3	Internal organization	2	2	0	2	0
A.4	Resources for AI systems	5	3	1	2	0
A.5	Assessing impacts of AI systems	4	4	0	4	0
A.6	AI system life cycle	9	4	4	0	0
A.7	Data for AI systems	5	0	0	0	0
A.8	Information for interested parties	4	4	3	1	0
A.9	Use of AI systems	3	3	1	2	0
A.10	Third-party and customer relationships	3	3	1	2	0
Total		**38**	**26**	**10**	**16**	**0**

Build narration. Twelve controls are excluded, all for the same reason: Cypher builds no AI. Each exclusion carries a trigger (the AI-A01 design gate), because an exclusion without a re-entry point is how scope quietly shrinks. Four life-cycle controls stay **in**: verification, deployment, operation and event logs apply to anyone who puts an AI system into use, not only to whoever built it. Nobody has checked whether ScribeCo's summaries are accurate, so A.6.2.4 scores 0.

All 38 controls

Control	Title	Applicable	Justification	Maturity (0-4)	Status	Evidence held / required	Owner	Finding	Roadmap	Target
A.2.2	AI policy	Y	Cypher uses three AI systems (AIS-01 to AIS-03).	1	Partial	Held: CGI-POL-001 s4.5 (four clauses on staff use; a fragment). Required: AI policy v1.0.	Chief Executive Officer	AF-08	AIG-07	31 Dec 2026
A.2.3	Alignment with other organizational policies	Y	AI use touches acceptable use, classification and supplier policies.	2	Partial	Held: s4.5 sits inside CGI-POL-001 and uses CGI-POL-004 classes. Required: evidence of a consistency review.	Chief Technology Officer	AF-08	AIG-07	31 Dec 2026
A.2.4	Review of the AI policy	Y	Needed once an AI policy exists.	1	Partial	Held: CGI-POL-001 annual review date. Required: review criteria covering new tools and legal change (the Omnibus rewrote Art. 4).	Chief Technology Officer	AF-08	AIG-07	31 Dec 2026
A.3.2	AI roles and responsibilities	Y	Owners exist per tool; nobody owns AI governance.	1	Partial	Held: CTO list-keeper role (s4.5.1). Required: AI lead, impact-assessment owner, reviewers.	Chief Executive Officer	AF-08	AIG-07	31 Dec 2026
A.3.3	Reporting of concerns	Y	Staff and customers see AI output first.	1	Partial	Held: CGI-POL-005 incident reporting (not AI-specific). Required: AI concern category and route.	Chief Technology Officer	AF-10	AIG-10	31 Jan 2027
A.4.2	Resource documentation	Y	A deployer must know what each system uses and touches.	1	Partial	Held: AI register drafted here. Required: register approved and kept current.	Chief Technology Officer	AF-03	AIG-03	31 Oct 2026
A.4.3	Data resources	Y	Applicable to the data Cypher feeds in.	1	Partial	Held: data-in column of the AI register (from the CGI-TPR-001 inventory). Required: owner confirmation.	Chief Technology Officer	AF-03	AIG-03	31 Oct 2026
A.4.4	Tooling resources	N	Not applicable while Cypher develops no AI system (AI register, Part 2). Becomes applicable at the AI-A01 design gate (AIG-13).	-	-	-	Chief Technology Officer	AF-13	AIG-13	31 Mar 2027
A.4.5	System and computing resources	N	Not applicable while Cypher develops no AI system (AI register, Part 2). Becomes applicable at the AI-A01 design gate (AIG-13). For supplier AI the computing is the supplier's.	-	-	-	Chief Technology Officer	AF-13	AIG-13	31 Mar 2027
A.4.6	Human resources	Y	Oversight needs	0	Not	Held: none. Required: AI	Head of	AF-05	AIG-08	31 Mar

Control	Title	Applicable	Justification	Maturity (0-4)	Status	Evidence held / required	Owner	Finding	Roadmap	Target
			competent reviewers.		started	roles in the competence matrix.	People and Operations			2027
A.5.2	AI system impact assessment process	Y	Two systems process people's conversations.	1	Partial	Held: process drafted in Part 5. Required: approval; trigger in CGI-TPR-001.	Chief Technology Officer	AF-07	AIG-05	30 Nov 2026
A.5.3	Documentation of AI system impact assessments	Y	Same.	1	Partial	Held: AIIA-01 and AIIA-02 (this document). Required: owner approval; retention rule.	Chief Technology Officer	AF-07	AIG-05	30 Nov 2026
A.5.4	Assessing impacts on individuals or groups	Y	Customers and staff are recorded on calls.	1	Partial	Held: harm tables in AIIA-01 and AIIA-02. Required: approval.	Chief Technology Officer	AF-07	AIG-05	30 Nov 2026
A.5.5	Assessing societal impacts of AI systems	Y	Required by the process even when the answer is small.	1	Partial	Held: societal section in AIIA-01 and AIIA-02 (negligible at this scale). Required: approval.	Chief Technology Officer	AF-07	AIG-05	30 Nov 2026
A.6.1.2	Objectives for responsible development of AI systems	N	Not applicable while Cypher develops no AI system (AI register, Part 2). Becomes applicable at the AI-A01 design gate (AIG-13).	-	-	-	Chief Technology Officer	AF-13	AIG-13	31 Mar 2027
A.6.1.3	Processes for responsible design and development	N	Not applicable while Cypher develops no AI system (AI register, Part 2). Becomes applicable at the AI-A01 design gate (AIG-13).	-	-	-	Chief Technology Officer	AF-13	AIG-13	31 Mar 2027
A.6.2.2	AI system requirements and specification	N	Not applicable while Cypher develops no AI system (AI register, Part 2). Becomes applicable at the AI-A01 design gate (AIG-13). Buying supplier AI is governed by A.10.3.	-	-	-	Chief Technology Officer	AF-13	AIG-13	31 Mar 2027
A.6.2.3	Documentation of AI system design and development	N	Not applicable while Cypher develops no AI system (AI register, Part 2). Becomes applicable at the AI-A01 design gate (AIG-13).	-	-	-	Chief Technology Officer	AF-13	AIG-13	31 Mar 2027
A.6.2.4	AI system verification and validation	Y	A deployer should test a tool on its own calls before trusting it. Nobody has checked ScribeCo's accuracy.	0	Not started	Held: none. Required: an acceptance test (sample of summaries checked against recordings).	Head of Customer Success	AF-06	AIG-09	31 Jan 2027
A.6.2.5	AI system deployment	Y	Every tool Cypher puts into use is a deployment.	0	Not started	Held: none; two tools arrived on expenses. Required: deployment checklist in the onboarding workflow.	Chief Technology Officer	AF-03	AIG-03	31 Oct 2026
A.6.2.6	AI system operation and monitoring	Y	Output errors are the AR-001 risk.	0	Not started	Held: none. Required: review log sample; error reporting.	Head of Customer Success	AF-06	AIG-09	31 Jan 2027
A.6.2.7	AI system technical documentation	N	Not applicable while Cypher develops no AI system (AI register, Part 2). Becomes applicable at the AI-A01 design gate (AIG-13). Supplier documentation is collected under A.8.2 and A.10.3.	-	-	-	Chief Technology Officer	AF-13	AIG-13	31 Mar 2027
A.6.2.8	AI system recording of event logs	Y	Cypher should know who used which tool on which meeting.	0	Not started	Held: none. Required: admin usage export kept 6 months.	IT Operations Manager	AF-03	AIG-03	31 Oct 2026
A.7.2	Data for development and enhancement of AI systems	N	Not applicable while Cypher develops no AI system (AI register, Part 2). Becomes applicable at the AI-A01 design gate (AIG-13). A supplier training on Cypher's data is a supplier control (A.10.3, VR-006).	-	-	-	Chief Technology Officer	AF-13	AIG-13	31 Mar 2027
A.7.3	Acquisition of data	N	Not applicable while Cypher develops no AI system (AI register, Part 2). Becomes applicable	-	-	-	Chief Technology Officer	AF-13	AIG-13	31 Mar 2027

Control	Title	Applicable	Justification	Maturity (0-4)	Status	Evidence held / required	Owner	Finding	Roadmap	Target
			at the AI-A01 design gate (AIG-13).							
A.7.4	Quality of data for AI systems	N	Not applicable while Cypher develops no AI system (AI register, Part 2). Becomes applicable at the AI-A01 design gate (AIG-13).	-	-	-	Chief Technology Officer	AF-13	AIG-13	31 Mar 2027
A.7.5	Data provenance	N	Not applicable while Cypher develops no AI system (AI register, Part 2). Becomes applicable at the AI-A01 design gate (AIG-13).	-	-	-	Chief Technology Officer	AF-13	AIG-13	31 Mar 2027
A.7.6	Data preparation	N	Not applicable while Cypher develops no AI system (AI register, Part 2). Becomes applicable at the AI-A01 design gate (AIG-13).	-	-	-	Chief Technology Officer	AF-13	AIG-13	31 Mar 2027
A.8.2	System documentation and information for users	Y	Staff need to know what each tool may and may not be used for.	0	Not started	Held: none; no AI-use instruction (OFI-04). Required: one-page use guide per approved tool.	Chief Technology Officer	AF-05	AIG-08	31 Dec 2026
A.8.3	External reporting	Y	Customers are the first to see a wrong summary.	0	Not started	Held: none. Required: customer route for AI concerns.	Head of Customer Success	AF-10	AIG-10	31 Jan 2027
A.8.4	Communication of incidents	Y	AI incidents can be data incidents.	1	Partial	Held: CGI-POL-005 customer and regulator communications (RS.CO = 2). Required: AI incident type.	Chief Technology Officer	AF-10	AIG-10	31 Jan 2027
A.8.5	Information for interested parties	Y	Customers on calls are not told they are transcribed.	0	Not started	Held: none. Required: call notice; AI sub-processors on the customer list.	Head of Customer Success	AF-09	AIG-06	30 Nov 2026
A.9.2	Processes for responsible use of AI systems	Y	Core control for a deployer.	2	Partial	Held: CGI-POL-001 s4.5.1 to s4.5.4 (approved). Contradicted by ScribeCo; cannot reach 3 until operating evidence exists. Required: approved list; review records.	Chief Technology Officer	AF-03	AIG-03	31 Oct 2026
A.9.3	Objectives for responsible use of AI systems	Y	Needed to measure the AIMS.	0	Not started	Held: none. Required: AI objectives (ISO-07).	Chief Technology Officer	AF-08	AIG-11	30 Jun 2027
A.9.4	Intended use of the AI system	Y	Stops drift into prohibited or high-risk uses.	1	Partial	Held: WriteCo extension scope restricted (CGI-TPR-001 condition). Required: intended-use and banned-use statement per tool.	Chief Technology Officer	AF-11	AIG-07	31 Dec 2026
A.10.2	Allocation of responsibilities	Y	All three systems in use are supplier AI.	2	Partial	Held: CGI-TPR-001 clause checklist incl. no-training clause (approved). Required: executed clauses for AI suppliers.	Chief Technology Officer	AF-01; AF-02	AIG-01; AIG-02	24 Oct 2026
A.10.3	Suppliers	Y	All three systems in use are supplier AI.	2	Partial	Held: T2-f and questionnaire domain 15, operated once (WriteCo). Not 3: no review cycle has run (same reason GV.SC = 2). Required: ScribeCo decision; ChatCo DPA.	Chief Technology Officer	AF-01; AF-02; AF-04	AIG-01; AIG-04	30 Nov 2026
A.10.4	Customers	Y	Cypher is a processor for ~200 customers.	0	Not started	Held: none for AI. Required: AI sub-processors in the customer list and the SOC-02 system description.	Chief Technology Officer	AF-12	AIG-12	30 Jun 2027

4.4 Readiness score and go / no-go

Same method as CGI-ISO-001: clauses weigh 60%, Annex A 40% (Implemented = 1, Partial = 0.5), and any failed gate means NO-GO.

Component	Calculation	Result	Weight
Clauses 4-10	18 ÷ 60	**30.0%**	60%
Annex A	(0 × 1 + 16 × 0.5) ÷ 26 applicable	**30.8%**	40%
Weighted readiness	0.6 × 30.0% + 0.4 × 30.8%	**30.3% — Not ready**	

Component	Calculation	Result	Weight
Gate failures	9 of 9	**NO-GO**	
Sensitivity: AI-A01 in scope	the 12 excluded controls join at 0: (16 × 0.5) ÷ 38	26.4% weighted	

NO-GO on an ISO/IEC 42001 Stage 1 audit. And the recommendation is not to pursue one before the ISO 27001 certificate (November 2027): what customers ask for today is an AI register, no-training contracts and straight answers to their AI questionnaires, not a second certificate. Decision point: Q1 2028 (AIG-15).

4.5 One joint management system

Because both standards share the Harmonized Structure, the clauses 7, 9 and 10 machinery already planned for ISO 27001 can carry the AIMS. **Reuse saves design effort, not readiness points:** CGI-ISO-001 found little operating evidence in those clauses, so reusing them reuses the gaps too.

Reuse as is	Extend	Build new (AI-specific)
7.5 document control · 9.2 internal audit programme (ISO-12) · 9.3 management review (ISO-13) · 10.1–10.2 corrective action (ISO-08, ISO-15) · 6.3 change planning · 7.2 competence matrix (ISO-10)	4.1–4.2 context and obligations (ISO-01) · 5.3 RACI (ISO-04) · 6.1.2 risk criteria (ISO-05) · 6.1.3 SoA approval (ISO-06) · 6.2 objectives (ISO-07) · 7.3 awareness (REC-09)	4.1 role per AI system · 5.2 AI policy · **6.1.4 / 8.4 AI system impact assessment** · Annex A A.5, A.9, A.10

Part 5 — Two AI impact assessments

5.1 Process and selection

The process (ISO/IEC 42001 6.1.4, A.5.2) runs for every AI system before first use, on any change of purpose or supplier terms, and every 12 months. Each assessment records data in, data out, affected people, model-training terms, human oversight and the GDPR link, then scores harms on the CGI-RSK-001 1–5 scales.

Which two: ranked by recorded inherent vendor risk, ties broken by whether the AI processes outsiders' content directly.

Rank	AI system ID	AI system	Inherent vendor risk (CGI-TPR-001)	External people whose content it processes directly	Selected for full assessment
1	AIS-01	ScribeCo meeting assistant	16	Yes: customers on calls	Yes (AIIA-01)
2	AIS-02	ChatCo AI features	12	Yes: customers in 3 shared channels	Yes (AIIA-02)
3	AIS-03	WriteCo writing assistant	12	No: reads what staff type	No: screening only (DPIA screening table)

5.2 AIIA-01 — ScribeCo meeting assistant

Section	Field	Content
Identity	System	AIS-01 ScribeCo meeting assistant (CGI-VEN-012)
Identity	Assessor / approver	O.S / Head of Customer Success (owner), then Chief Executive Officer
Identity	Date and trigger	17 Oct 2026. Trigger: shadow AI found 15 Sep 2026; no contract; decision overdue since 15 Oct 2026
Use	Intended use	Notes and summaries of internal and customer calls for Customer Success
Use	Uses that must never happen	Assessing staff performance from calls (Annex III 4(b)); inferring emotions from voice at work (Art. 5(1)(f))
Data	Data in	Live audio of about 40 meetings a month: voices, names, commercial terms, security discussion, any personal data spoken
Data	Data out	Transcripts, summaries and action items, stored by ScribeCo in the United States and shared by link
Data	Model-training terms	Unknown. No contract and no terms review, so VQ-68 and VQ-69 cannot be answered. Treat as 'may train, may review'
People	Affected people	Customer participants (individuals and their companies); Cypher staff (employees: power imbalance); third parties named on calls
Oversight	Human oversight today	None recorded. CGI-POL-001 s4.5.3 requires a competent person to review AI output before it reaches a customer
Oversight	Oversight required	Human-in-the-loop: the call owner checks every summary before it leaves Cypher; monthly sample of 10 checked against recordings
GDPR	Cypher's GDPR role	Controller: these are Cypher's own business calls, so Cypher (not its customers) decides why and how they are recorded
GDPR	Art. 28 contract	None. ScribeCo processes personal data for Cypher with no Art. 28 terms (VR-001); no transfer mechanism for US hosting (Arts 44-46)
GDPR	Art. 35 DPIA	Required: 4 of the 9 EDPB criteria met (see DPIA screening). Must be done before any further use

Section	Field	Content
GDPR	Arts 13-14 notice	Not given. People on calls are not told the call is recorded and transcribed by a third party
Societal	Societal impact	Negligible at this scale (one company's calls). Recorded so the process is complete (A.5.5)
Decision	Recommendation	Suspend now. Then either contract (DPA, no training, no human review, EU or covered transfer, 30-day retention, deletion on exit) with notice, DPIA and review step, or exit with a deletion certificate. Without a contract the residual stays at 16

Harms, scored

Harm	What could happen	Who	Now (L × I)	Measures	Type	After (L × I)
H1	Call content retained, reviewed or used for training by a supplier under no contract	Customer participants; Cypher	4 × 4 = **16**	DPA with no-training and no-human-review clauses and a transfer mechanism (brakes); 30-day retention and deletion on exit (seatbelt)	Brakes and seatbelt (two measures)	2 × 3 = **6**
H2	A wrong summary is acted on or sent to a customer (misstated commitments)	Customers	3 × 3 = **9**	Call owner reviews every summary before it leaves Cypher (brakes); monthly accuracy sample of sent summaries (seatbelt: finds what slipped through)	Brakes, checked by a seatbelt	2 × 3 = **6**
H3	People are recorded without being told	Customer participants; staff; third parties	4 × 2 = **8**	Spoken and written notice at the start of every recorded call; bot shown by name	Brakes	1 × 2 = **2**
H4	Use drifts into judging staff, or emotion inference from voice	Staff	2 × 4 = **8**	Banned-use statement in the AI policy; feature check in AIG-04	Brakes	1 × 4 = **4**

Result: worst harm **16 → 6** once the measures are in place. Without a contract, H1 stays at 16 and the only safe answer is exit.

5.3 AIIA-02 — ChatCo AI features

Section	Field	Content
Identity	System	AIS-02 ChatCo AI features (CGI-VEN-004)
Identity	Assessor / approver	O.S / IT Operations Manager (owner), then Chief Technology Officer
Identity	Date and trigger	17 Oct 2026. Trigger: VRA-2026-002 F-004; action R4 due 01 Oct 2026 with no completion evidence
Use	Intended use	Answers and channel summaries for staff inside ChatCo
Use	Uses that must never happen	Scoring staff from chat behaviour (Annex III 4(b)); using AI summaries as the incident record (CGI-POL-005 decision log stays human)
Data	Data in	All message content the user can see: internal discussion, pasted credentials and screenshots, incident traffic, customers' posts in 3 shared channels
Data	Data out	AI answers and summaries shown inside ChatCo
Data	Model-training terms	Not Met: training not contractually prohibited; human review not excluded (F-004; VQ-68, VQ-69)
People	Affected people	Cypher staff (employees); customer staff posting in shared channels
Oversight	Human oversight today	None recorded; summaries are internal and unchecked
Oversight	Oversight required	Human-on-the-loop: summaries labelled as AI and never used as the incident record; switch-off control kept with the IT Operations Manager
GDPR	Cypher's GDPR role	Controller for its own workspace content
GDPR	Art. 28 contract	Not executed (F-001; VR-001)
GDPR	Art. 35 DPIA	Required before re-enabling: 3 of the 9 EDPB criteria met
GDPR	Arts 13-14 notice	Customers in shared channels are not told their posts may be processed by AI
Societal	Societal impact	Negligible at this scale
Decision	Recommendation	Confirm the features are off today (screenshot). Re-enable only after a DPA with no-training and no-human-review clauses, a DPIA, retention limits (F-005) and AI switched off in shared channels

Harms, scored

Harm	What could happen	Who	Now (L × I)	Measures	Type	After (L × I)
H1	Message content (credentials, customer posts) used for training or human review	Staff; customers in shared channels	4 × 4 = **16**	Features off until a DPA with no-training and no-human-review clauses	Brakes	1 × 4 = **4**
H2	Customers in shared channels unaware their posts are processed by AI	Customer staff	3 × 2 = **6**	AI off in shared channels; notice in channel description	Brakes	1 × 2 = **2**
H3	A wrong incident-channel summary misleads the response	Customers (indirectly)	2 × 3 = **6**	Rule: AI summaries are never the incident record	Brakes	1 × 3 = **3**
H4	AI answers make pasted credentials and customer detail easier to find	Staff; customers	3 × 3 = **9**	Retention limit (F-005); credential-pasting rule; secret rotation if found	Brakes	2 × 3 = **6**

Result: worst harm **16 → 6**.

Build narration. Almost every measure here is **brakes**: it acts before the harm. A human check before a summary leaves Cypher prevents the harm; it does not shrink it, so those "after" scores fall on likelihood. **Only one impact score falls (AIIA-01 H1, 4 → 3), and a seatbelt explains it:** a 30-day retention limit does not stop a supplier misusing call content, but it caps how much content any misuse can reach. If impact falls in a table like this and you cannot name the seatbelt, the score is wrong.

5.4 DPIA screening (GDPR Article 35)

For its own calls and its own chat workspace, Cypher is the **controller**, so the DPIA duty is Cypher's.

EDPB criterion	AIS-01 ScribeCo	AIS-02 ChatCo AI features	AIS-03 WriteCo
1. Evaluation or scoring	No	No	No
2. Automated decision with legal or similar effect	No	No	No
3. Systematic monitoring	Yes: every recorded call	No	No
4. Sensitive or highly personal data	Yes: private communications	Yes: private communications	Yes: anything typed
5. Large scale	No	No	No
6. Matching or combining datasets	No	No	No
7. Vulnerable data subjects (employees)	Yes	Yes	Yes
8. Innovative use or new technology	Yes	Yes	Yes
9. Prevents exercising a right or using a service	No	No	No
Criteria met	**4**	**3**	**3**

EDPB guidance: two or more criteria met usually means a DPIA is required (GDPR Art. 35). **All three tools need a DPIA**, ScribeCo before any further use and ChatCo AI before it is switched back on.

Part 6 — Multi-framework mapping

Each finding is mapped across seven columns. **Where no counterpart exists, the table says "None" and why**, rather than forcing a fit. SOC 2 has no AI-specific criterion, and CGI-SOC-001's overlap analysis already found that A.5.31 (legal and regulatory requirements) has no criterion counterpart.

Finding ID	Severity	EU AI Act	ISO/IEC 42001	ISO/IEC 27001:2022 Annex A	SOC 2 (TSC)	NIST CSF 2.0	NIST AI RMF	Risk ID
AF-01	Critical	None directly (Art. 4 only). The duty broken is GDPR Arts 28 and 44-46	A.10.2; A.10.3; 8.1	A.5.19; A.5.20; A.5.34	CC9.2	GV.SC	GOVERN	VR-001; VR-005; VR-006; R-003
AF-02	High	None (ChatCo holds the provider duties). GDPR Art. 28	A.10.2; A.10.3	A.5.20; A.5.34	CC9.2	GV.SC; PR.DS	GOVERN; MAP	VR-006; VR-001
AF-03	Medium	Art. 4 (a measure staff can follow)	A.9.2; A.4.2; A.6.2.5; 8.1	A.5.10; A.5.9	CC5.3	GV.PO; ID.AM	GOVERN; MAP	VR-005
AF-04	High	Art. 5; Art. 6(2) and Annex III	4.1; A.4.2; A.10.3	A.5.9; A.5.31	None: CGI-SOC-001 found A.5.31 has no criterion counterpart	ID.AM; GV.OC	MAP	VR-005; AR-002
AF-05	Medium	Art. 4	7.2; 7.3; A.4.6; A.8.2	A.6.3	CC1.4; CC2.2	PR.AT	GOVERN	VR-005; VR-006; AR-001
AF-06	Medium	None: Arts 14 and 26 apply to high-risk systems only. Voluntary alignment	A.6.2.4; A.6.2.6; A.9.2	None: Annex A has no control for output accuracy (nearest A.5.10)	None in scope: Processing Integrity is outside Cypher's SOC 2 scope	None: CSF 2.0 has no Category for output accuracy (nearest GV.PO)	MEASURE; MANAGE	AR-001
AF-07	High	None for Cypher (Art. 27 FRIA applies only to certain deployers of high-risk systems). GDPR Art. 35	6.1.4; 8.4; A.5.2; A.5.3; A.5.4	A.5.34	None: Privacy is outside Cypher's SOC 2 scope (SOC-A03)	ID.RA; GV.OC	MAP	VR-006; VR-001
AF-08	Medium	Art. 4 (measures need an owner)	4.3; 5.2; 5.3; A.2.2; A.3.2	A.5.1; A.5.2	CC1.3; CC5.3	GV.PO; GV.RR	GOVERN	VR-005; VR-006; AR-002
AF-09	High	None for Cypher as deployer (Art. 50(3)-(4) not triggered). GDPR Arts 13-14	A.8.5; A.10.4	A.5.34	CC2.3	GV.OC	GOVERN; MAP	VR-006
AF-10	Medium	None directly	A.3.3; A.8.3; A.8.4	A.5.24; A.6.8	CC2.3; CC7.3	RS.MA; RS.CO	MANAGE	AR-001
AF-11	Medium	Art. 5(1)(f); Art. 6(2) and Annex III point 4; Art. 25(1)(c)	A.9.4; A.2.2	A.5.31	None: CGI-SOC-001 found A.5.31 has no criterion counterpart	GV.OC	GOVERN; MAP	AR-002
AF-12	Low	None	A.10.4	A.5.20	CC2.3	GV.SC	GOVERN	VR-001
AF-13	Medium	Art. 3(3); Art. 50(1)-(2); Art. 6(2) and Annex III 4(b); Art. 4	A.6.1.2; A.6.1.3; A.6.2.2; A.5.2; A.8.2	A.5.8; A.8.25; A.8.26	CC3.4; CC8.1	GV.OC; ID.RA	MAP; MEASURE	R-004; AR-002

What the "None" cells teach. Output accuracy (AF-06) has no home in ISO/IEC 27001, SOC 2 (in Cypher's scope) or CSF 2.0. Only ISO/IEC 42001 and the AI RMF cover it. That is the clearest single answer to "why does AI need its own governance?"

Part 7 — Findings register

7.1 Severity rule, published before grading

Severity	Rule
Critical	Customer or personal data is processed by an AI system today under no contract of any kind, or a prohibited practice (Art. 5) is in use.
High	A legal duty in force today is unmet (GDPR Arts 13-14, 28, 35; AI Act Art. 4 with no measure at all), or customer content sits under no training or human-review prohibition, or Cypher cannot tell whether it has a prohibited or high-risk use.
Medium	An approved policy control or a required management-system process is absent or unevidenced, with no legal duty unmet today.
Low	A documentation or customer-assurance gap with no exposure.

7.2 Register

13 findings: 1 Critical, 4 High, 7 Medium, 1 Low.

ID	Severity	Finding	What we found	Remediation	Effort	Owner	Due	Roadmap	Risk ID
AF-01	Critical	ScribeCo records customer calls with no contract of any kind	AIS-01 joins internal and customer calls and stores audio and transcripts in the United States. There is no contract, DPA or transfer mechanism. CGI-TPR-001 set a decision for 15 Oct 2026; none is recorded.	Today: remove the bot from all calls. By 24 Oct: CEO decides contract (DPA, no training, no human review, transfer mechanism, 30-day retention, deletion on exit) or exit with a deletion certificate. Record a nonconformity against CGI-POL-001 s4.5.	S	Head of Customer Success	24 Oct 2026	AIG-01	VR-001; VR-005; VR-006; R-003
AF-02	High	ChatCo's AI reads customer content under no training prohibition, and the switch-off is unevidenced	F-004 (15 Sep 2026): AI features process message content, including customers' posts in 3 shared channels; training not prohibited, human review not excluded. Action R4 (switch off by 01 Oct 2026) has no completion evidence.	Screenshot the admin setting showing AI off (today). Keep off until the DPA includes no-training and no-human-review clauses (ISO-09).	S	Chief Technology Officer	24 Oct 2026	AIG-02	VR-006; VR-001
AF-03	Medium	The approved AI tools list the policy depends on does not exist	CGI-POL-001 s4.5.1 tells staff to use only tools on the CTO's approved list. No list is recorded anywhere, so staff cannot comply and nobody can check.	Publish list v1 (WriteCo with conditions; ScribeCo and ChatCo AI pending) and adopt the AI register from Part 2 as its record.	S	Chief Technology Officer	31 Oct 2026	AIG-03	VR-005
AF-04	High	Cypher cannot yet prove it has no prohibited or high-risk AI use	VQ-67 answers are recorded for ChatCo only. AI features of HRCo, SupportCo, CRMCo, OfficeCo and the other suppliers are unconfirmed, so AI-A02 and AI-A03 are assumptions.	Run an AI-feature census: VQ-67 and VQ-68 to all 17 suppliers; confirm HRCo has no screening or evaluation features in use.	M	Chief Technology Officer	30 Nov 2026	AIG-04	VR-005; AR-002
AF-05	Medium	AI literacy measures cover 60% of staff and say nothing specific about AI	CGI-POL-001 (with s4.5) is acknowledged by 60% of staff. No AI-use module exists (OFI-04). Some measure exists, so the Art. 4 duty is partly met, not unmet.	AI-use module for every staff member who uses AIS-01 to AIS-03, with a completion record; pulled forward from REC-09.	S	Head of People and Operations	31 Dec 2026	AIG-08	VR-005; VR-006; AR-001
AF-06	Medium	No record that AI output is checked before it reaches a customer	CGI-POL-001 s4.5.3 requires a competent person to review AI output before it is sent to a customer. No review record or reviewer exists, and nobody has tested ScribeCo's accuracy.	Named reviewers per tool; review step and log; monthly sample of 10 summaries checked against recordings.	M	Head of Customer Success	31 Jan 2027	AIG-09	AR-001
AF-07	High	No DPIA was done for three AI tools that meet the DPIA criteria	Screening against the nine EDPB criteria: ScribeCo meets 4, ChatCo AI 3, WriteCo 3. Two or more usually means a DPIA is required. None has one.	DPIA for ScribeCo before any further use, and for ChatCo AI before re-enabling; WriteCo by 30 Nov. Add the trigger to CGI-TPR-001.	M	Chief Technology Officer	30 Nov 2026	AIG-05	VR-006; VR-001
AF-08	Medium	No AI policy, AIMS scope or AI roles	The only AI rules are four clauses in CGI-POL-001 s4.5. Nobody owns AI governance.	AI policy v1.0 (extends s4.5; banned uses; impact-assessment rule), AIMS scope statement and AI roles in the ISO-04 RACI.	M	Chief Executive Officer	31 Dec 2026	AIG-07	VR-005; VR-006; AR-002
AF-09	High	People on recorded calls are not told	Customers and staff on ScribeCo calls, and customers in ChatCo shared channels, are not told their words are processed by a third-party AI.	Spoken and written notice on every recorded call; channel notice; AI sub-processors added to the customer-facing list.	S	Head of Customer Success	30 Nov 2026	AIG-06	VR-006
AF-10	Medium	No route to report a harmful or wrong AI output	CGI-POL-005 covers security incidents. Nothing tells staff or customers how to report a wrong summary or misuse of an AI tool.	Add an 'AI output or misuse' category to CGI-POL-005 reporting, and a customer contact route.	S	Chief Technology Officer	31 Jan 2027	AIG-10	AR-001
AF-11	Medium	Nothing stops an approved tool being used for a banned or high-risk purpose	Onboarding controls new tools, not new uses. HR could use WriteCo to rank applicants (Annex III 4(a), and Art. 25(1)(c) would make Cypher the provider) or switch on voice emotion analysis (Art. 5(1)(f)).	Banned-use list in the AI policy; intended use recorded per tool in the register; HR sign-off for any AI touching staff decisions.	S	Chief Executive Officer	31 Dec 2026	AIG-07	AR-002

ID	Severity	Finding	What we found	Remediation	Effort	Owner	Due	Roadmap	Risk ID
AF-12	Low	AI suppliers are missing from what customers are told about Cypher's service	The draft system description and customer obligations (SOC-02) do not mention AI suppliers or AI features.	Add AI suppliers and any AI-related customer obligations to SOC-02 and the trust page (SOC-13).	S	Chief Technology Officer	30 Jun 2027	AIG-12	VR-001
AF-13	Medium	Scenario AI-A01: no design gate for Cypher's first AI product feature	The planned project assistant would make Cypher a provider with Art. 50 duties at launch. No intended-purpose statement, design controls (A.6, A.7) or supplier assessment of ModelCo exists, and CGI-POL-007 (secure development) is not yet written.	Design gate before any build: intended-purpose statement excluding staff evaluation; Art. 50 design requirements; impact assessment; ModelCo assessed as Tier 1 under CGI-TPR-001.	M	Chief Technology Officer	31 Mar 2027	AIG-13	R-004; AR-002

Build narration. AF-05 (AI literacy) is Medium, not High, and the reason matters. The severity rule makes an unmet legal duty High only when **no** measure exists. Sixty per cent of staff have acknowledged a policy that contains AI rules, so a measure exists; it is thin, not absent. Sizing a finding to the rule, not to how important the topic sounds, is what makes a register defensible.

Part 8 — Risk register: CGI-RSK-001 v1.3

8.1 The drawer-2 test

A finding becomes a new risk only if the existing risk's controls would **not** have prevented it. Otherwise it is a new route into an existing risk.

Candidate event	Existing risk considered	Would its controls have prevented it?	Decision
ScribeCo processes customer call audio under no contract	VR-001	Yes: Gate B (no DPA, no onboarding) stops exactly this	Existing risk, new route: VR-001 already lists CGI-VEN-012. No new risk
A supplier trains on or reviews Cypher's content	VR-006	Yes: it is VR-006's own scenario	Existing risk. No new risk
A team adopts an AI tool with no review	VR-005	Yes, when the tool is paid for or connected	Existing risk. No new risk
Staff paste Confidential data into a free web AI tool	VR-005	No: expense and OAuth reconciliation cannot see a free browser tool, though VR-005's scenario names free tiers	Existing risk, control gap: flag VR-005's residual for the Q1 2027 review (same treatment as R-001 in CGI-AWS-001). No new risk
Inaccurate AI output is acted on or sent to a customer	VR-006; VR-005	No: neither control set touches output accuracy	NEW RISK AR-001
An approved tool is used for a prohibited or Annex III purpose	VR-005	No: the gate checks tools at purchase, not later uses	NEW RISK AR-002

8.2 The two new risks

Risk ID	Title	Owner	Inherent	Controls credited	Residual	Treatment	Target	Why it is new
AR-001	Inaccurate AI output is acted on or sent to a customer	Head of Customer Success	4 × 3 = 12 High	CGI-POL-001 s4.5.3 (review before sending) credited at partial strength: approved, unevidenced, likelihood 4 -> 3. Nothing reduces impact.	3 × 3 = **9 Medium**	TP-11: named reviewers, review log, monthly accuracy sample (AIG-09); AI-use module (AIG-08)	6 (L2 x I3)	NEW. VR-006's controls govern what suppliers do with Cypher's data, not whether output is right; VR-005's govern which tools arrive; an approved tool can still be wrong.
AR-002	An AI tool is used for a prohibited or high-risk purpose without classification	Chief Executive Officer	2 × 4 = 8 Medium	None credited: the onboarding gate (VR-005) checks new tools, not new uses of approved ones.	2 × 4 = **8 Medium**	TP-12: banned-use list and intended-use field per tool (AIG-07); HR sign-off; supplier feature census (AIG-04)	4 (L1 x I4)	NEW. VR-005's gate is inert against a new use of an approved tool, and no other risk covers regulatory classification.

8.3 Totals before and after

	v1.2 (after CGI-AWS-001)	v1.3 (after CGI-AIG-001)
Risks	14	**16**
Inherent total	213	**233**
Residual total	130	**147**
Reduction	39.0%	**36.9%**
Mean residual	9.29	**9.19**
Residual Critical / High	1 / 2	**1 / 2** (unchanged: R-005; R-004, VR-004)

The reduction falls because two risks enter with little or no credited control. That is the honest direction: the register now sees something it was blind to.

Risk ID	Inherent	Residual v1.2	Rating v1.2	Residual v1.3	Rating v1.3	Change
R-001	20	6	Medium	6	Medium	0
R-002	20	8	Medium	8	Medium	0
R-003	12	6	Medium	6	Medium	0
R-004	20	12	High	12	High	0
R-005	20	20	Critical	20	Critical	0
VR-001	16	8	Medium	8	Medium	0
VR-002	10	8	Medium	8	Medium	0
VR-003	12	8	Medium	8	Medium	0
VR-004	15	12	High	12	High	0
VR-005	12	9	Medium	9	Medium	0
VR-006	16	9	Medium	9	Medium	0
VR-007	12	9	Medium	9	Medium	0
VR-008	16	9	Medium	9	Medium	0
VR-009	12	6	Medium	6	Medium	0
AR-001	12	-	-	**9**	Medium	New
AR-002	8	-	-	**8**	Medium	New
Total (16)	**233**	130		**147**		+17

Part 9 — Remediation roadmap and reconciliation

9.1 AIG-01 to AIG-15

ID	Phase	Action	Closes	Owner (job title)	Due	Est. cost (USD)	Reconciles with
AIG-01	Phase 0 - Contain	Remove ScribeCo from all calls today; CEO decision by 24 Oct: contract (DPA, no training, no human review, transfer mechanism, 30-day retention, deletion on exit) or exit with a deletion certificate; log the s4.5 breach as a nonconformity	AF-01	Head of Customer Success	24 Oct 2026	0	CGI-TPR-001 ScribeCo decision (due 15 Oct, overdue - AC-01); ISO-09
AIG-02	Phase 0 - Contain	Evidence ChatCo AI is off (admin screenshot); keep it off until the DPA carries no-training and no-human-review clauses	AF-02	Chief Technology Officer	24 Oct 2026	0	VRA-2026-002 R4 (due 01 Oct, unevidenced - AC-02); ISO-09
AIG-03	Phase 0 - Contain	Publish the approved AI tools list v1 and adopt the Part 2 AI register as its record; deployment checklist and usage-log export in onboarding	AF-03	Chief Technology Officer	31 Oct 2026	0	CGI-POL-001 s4.5.1; CGI-TPR-001 workflow
AIG-04	Phase 1 - Foundation	AI-feature census: VQ-67 and VQ-68 to all 17 suppliers; confirm no Annex III or Art. 5 use (HRCo first)	AF-04	Chief Technology Officer	30 Nov 2026	0	REC-15 cadence; REC-05 inventory
AIG-05	Phase 1 - Foundation	DPIAs for ScribeCo (before any further use), ChatCo AI (before re-enabling) and WriteCo; approve the impact-assessment process and add its trigger to CGI-TPR-001	AF-07	Chief Technology Officer	30 Nov 2026	0	ISO-09 (A.5.34)
AIG-06	Phase 1 - Foundation	Call-recording and channel notices; AI suppliers added to the customer-facing sub-processor list	AF-09	Head of Customer Success	30 Nov 2026	0	SOC-02; SOC-13
AIG-07	Phase 1 - Foundation	AI policy v1.0 (extends CGI-POL-001 s4.5; banned uses; intended use per tool), AIMS scope statement, AI roles in the RACI, AI resourcing line	AF-08; AF-11	Chief Executive Officer	31 Dec 2026	0	ISO-03; ISO-04 (AC-07)
AIG-08	Phase 1 - Foundation	AI-use module for every AI user, with completion records (the Art. 4 evidence)	AF-05	Head of People and Operations	31 Dec 2026	0	REC-09 (AI part pulled forward - AC-03); OFI-04
AIG-09	Phase 2 - Operate	Human-review procedure: named reviewers, review log, monthly accuracy sample	AF-06	Head of Customer Success	31 Jan 2027	0	TP-11 (AR-001)
AIG-10	Phase 2 - Operate	'AI output or misuse' reporting category in CGI-POL-005; customer contact route; AI scenario in the REC-12 tabletop	AF-10	Chief Technology Officer	31 Jan 2027	0	REC-12
AIG-11	Phase 2 - Operate	Join the AIMS to the ISMS: AI risk criteria into ISO-05, objectives into ISO-07, AIMS in the ISO-12 audit and ISO-13 reviews, one combined SoA approval at ISO-06	Clauses 6.1.2, 6.2, 9.2, 9.3	Chief Executive Officer	30 Jun 2027	0	ISO-05; ISO-06; ISO-07; ISO-12; ISO-13 (AC-07)
AIG-12	Phase 2 - Operate	AI suppliers and AI obligations in the system description and customer obligations	AF-12	Chief Technology Officer	30 Jun 2027	0	SOC-02
AIG-13	Phase 2 - Operate	AI-A01 design gate (scenario): intended purpose excluding staff evaluation; Art. 50 design; impact assessment; ModelCo assessed as Tier 1; Annex A A.6 and A.7 controls brought into scope	AF-13	Chief Technology Officer	31 Mar 2027	0	REC-06 (CGI-POL-007 must exist first - AC-06)

ID	Phase	Action	Closes	Owner (job title)	Due	Est. cost (USD)	Reconciles with
AIG-14	Phase 3 - Sustain	Quarterly AI reconciliation (KRI-V4 extended to AI features); annual register and policy review	AF-03; AF-04	Finance Manager	31 Mar 2027	0	KRI-V4
AIG-15	Phase 3 - Sustain	Buy ISO/IEC 42001 and decide on certification after the ISO 27001 certificate; not before Q1 2028	Clauses 4-10	Chief Executive Officer	31 Mar 2028	Standard purchase (planning estimate USD 200)	ISO-16; ISO-17 (AC-08)

Cost. Phases 0 to 2 need no new spend: they are decisions, signatures, settings and staff time. The only purchase is the ISO/IEC 42001 standard itself (planning estimate). If ScribeCo is retained, its subscription moves from an expense claim to a company contract.

9.2 Conflicts with earlier deliverables, stated and resolved

ID	Earlier deliverable says	The evidence says	Resolution
AC-01	CGI-TPR-001 set the ScribeCo decision for 15 Oct 2026.	No decision is recorded in any later deliverable.	Treated as overdue. AIG-01 suspends use now and resets the decision to 24 Oct 2026.
AC-02	VRA-2026-002 action R4: switch ChatCo AI off by 01 Oct 2026, evidenced by an admin screenshot.	No screenshot is recorded.	Treated as not done (AI-A04). AIG-02 asks for the evidence, not a new action.
AC-03	REC-09 schedules the awareness curriculum for Q1 2027.	Art. 4 has applied since 02 Feb 2025 and is supervised since 02 Aug 2026.	The AI-use module is pulled forward to 31 Dec 2026 (AIG-08); the rest of REC-09 keeps its date.
AC-04	The Part 1 teaching notes said CGI-SOC-001 noted SOC 2 has no AI criterion.	CGI-SOC-001 listed 11 Annex A controls and 7 clause requirements with no criterion (including A.5.31). It said nothing about AI.	Corrected. This document makes the 'no criterion' calls itself and cites CGI-SOC-001 only for A.5.31.
AC-05	CGI-TPR-001 counts 17 suppliers and 6 without a DPA (KRI-V1 65%).	If AIG-01 ends in exit, ScribeCo leaves the inventory.	Re-state KRI-V1 on the new base (16 suppliers) with a note; never change a denominator silently.
AC-06	AI-A01's design gate falls on 31 Mar 2027.	REC-06 (CGI-POL-007 secure development) is due in Q1 2027; a product AI feature needs it first.	AIG-13 cannot pass before REC-06 is approved. Launch stays 01 Sep 2027 (scenario).
AC-07	ISO-05 (risk acceptance criteria) and ISO-04 (RACI) cover information security only.	ISO/IEC 42001 6.1.2 needs criteria for harm to people; 5.3 needs AI roles.	Extend ISO-05 and ISO-04 instead of creating parallel actions (AIG-07, AIG-11). Their due dates do not move.
AC-08	CGI-ISO-001 targets ISO 27001 certification in November 2027.	A parallel ISO/IEC 42001 certificate would compete for the same people.	No 42001 certification before the 27001 certificate. Build the joint system now; decide in Q1 2028 (AIG-15).

9.3 What does not change

- **ISO 27001 certification stays November 2027** (CGI-ISO-001). Every AIG action that touches ISO actions extends them; none moves their dates.
- **The SOC 2 path stays** (Type I as of 31 Mar 2028). AIG-12 adds AI suppliers to SOC-02's system description.
- **REC-01 to REC-18, ISO-01 to ISO-17, SOC-01 to SOC-14, AWS-01 to AWS-18, CF-01 to CF-15 and CG-01 to CG-06 keep their IDs, owners and dates.** One is pulled forward in part (REC-09, AC-03); none is deleted.

Part 10 — Effect on maturity

10.1 CGI-GAP-001: 1.32 stays 1.32

Category	Name	Before	After	Why	What would move it
GV.OC	Organizational Context	1	1	AI roles and intended purposes are drafted here, not approved. A draft is a prerequisite, not a score.	2 when ISO-01 (now including the AI context and role statement) is CEO-approved.
GV.RM	Risk Management Strategy	2	2	AR-001 and AR-002 use the existing method, but there are still no acceptance criteria, for AI or anything else.	3 when ISO-05's criteria (with AI harm criteria) are approved and the cadence has run.
GV.PO	Policy	2	2	CGI-POL-001 s4.5 is approved but unevidenced: that is already a 2. A new AI policy would also be approved but unevidenced, so it could not lift it either.	3 when policy acknowledgement is evidenced at 100% and the AI-use module has run (REC-04, AIG-08).
ID.AM	Asset Management	1	1	The AI register lists four systems. Like Project 7's cloud resource list, it is an input to REC-05, not an asset inventory.	2 when REC-05 delivers the inventory with owners and classification, AI tools included.
PR.AT	Awareness and Training	1	1	No AI module has run.	2 when the AI module is approved and scheduled; 3 with completion records (AIG-08, REC-09).
GV.SC	Cybersecurity Supply	2	2	T2-f operated once (WriteCo); ScribeCo and	3 after a full review cycle on cadence

Category	Name	Before	After	Why	What would move it
	Chain Risk Management			ChatCo AI show the programme not yet holding.	(unchanged from CGI-ISO-001).

No Category moves.

- An AI register is a prerequisite, not a score. It feeds REC-05; it is not an asset inventory.
- An approved but unevidenced control is a 2, so writing an AI policy could not lift GV.PO above the 2 it already has.
- **The arithmetic:** the 22 Category scores sum to 29 before and after, so 29 ÷ 22 = **1.32**.

10.2 CGI-ISO-001 and CGI-SOC-001

No ISO 27001 control changes status, and readiness stays at 30.6%. The Evidence column gains new references: A.5.10 (ScribeCo breach confirmed as a nonconformity), A.5.20 (AI clauses not executed for three AI suppliers), A.5.34 (DPIA required for three tools), A.6.3 (no AI module). **SOC 2 readiness is unchanged** (Type I 53.9%, Type II 36.0%).

Part 11 — One-page executive summary

To: Jerry Gold, Chief Executive Officer · **From:** O.S · **Date:** 17 October 2026 · **Subject:** Are we using AI safely, and does the new EU AI law catch us?

In three sentences.

1. We use three AI tools, all bought from suppliers, and none of them is high-risk or banned under the EU AI Act, so the law asks two things of us today: train our people on the AI they use, and never use the practices it bans.
2. The real risk is how the tools arrived: the meeting assistant records customer calls under no contract at all (its decision was due two days ago), the chat tool's AI reads customer posts with nothing stopping the supplier training on them, and the approved-tools list our policy points to does not exist.
3. **Decision: GO** on suspending the meeting assistant and proving the chat AI is off, today, at no cost; **NO-GO** on an AI certificate before our ISO 27001 certificate in November 2027.

What we need from you

#	Decision	By
1	Approve suspending ScribeCo from all calls (AIG-01)	Today
2	Decide: contract ScribeCo properly, or exit with a deletion certificate	24 Oct 2026
3	Approve CGI-RSK-001 v1.3 (two new AI risks; you own AR-002)	31 Oct 2026
4	Approve the AI policy, scope and roles (AIG-07)	31 Dec 2026
5	Confirm we revisit ISO/IEC 42001 certification in Q1 2028, not before	31 Dec 2026

What does not change: the ISO 27001 target (November 2027), the SOC 2 path and the maturity score (1.32). **What happens if we do nothing:** a customer asks "where did the recording of our call go?" and we cannot answer.

Appendix A — Verification, assumptions and limitations

A.1 Verification performed in code, not by eye

Check	Result
ISO/IEC 42001 Annex A: 38 controls, 9 groups, IDs and titles checked against a published control list	Match (3 · 2 · 5 · 4 · 9 · 5 · 4 · 3 · 3)
Status derived from maturity for every applicable control	10 Not started · 16 Partial · 0 Implemented
Clause score, Annex A score and weighted readiness recomputed in code and as workbook formulas	30.0% · 30.8% · 30.3%
AI Act dates checked on 17 Oct 2026 against Regulation (EU) 2026/1744 and secondary sources	All five prompt dates confirmed; two more added (27 Jul 2026, 2 Dec 2026)
Every finding cited by the roadmap; every roadmap ID cited exists; finding and mapping rows align	Pass
Register totals recomputed from all 16 risks	233 inherent · 147 residual
CSF maturity recomputed from all 22 Categories	29 ÷ 22 = 1.32, unchanged
Workbook recalculated in LibreOffice	0 formula errors; 26 of 26 issue-checklist rows PASS
Simulated supplier names only	No real vendor name in any public file

A.2 Assumptions and limitations

ID	Type	Statement	Effect
AI-A01	Assumption	Cypher plans an in-product AI project assistant built on a third-party general-purpose model (ModelCo). Design gate 31 Mar 2027; launch not before 01 Sep 2027.	Tests the provider role. Declared after 16 Oct 2026 and kept out of every earlier project's numbers: ModelCo is not supplier 18, and no risk score, maturity score or SoA status uses it.
AI-A02	Assumption	ScribeCo is used for transcription and summaries only. No feature infers emotions from voice and no output is used to assess staff.	Unverified (no contract, no product review). If either is false, Art. 5(1)(f) or Annex III point 4(b) applies. Verified through AIG-04.
AI-A03	Assumption	No supplier AI feature is used for recruitment, staff evaluation, credit or other Annex III purposes.	Rests on what earlier projects record. HRCo, SupportCo, CRMCo and OfficeCo have no recorded VQ-67 answer. Verified through AIG-04 (finding AF-04).
AI-A04	Assumption	ChatCo's AI features are still switched on.	VRA-2026-002 action R4 was due 01 Oct 2026 and no later deliverable records it done. Never assume evidence an earlier project records as absent.
L-01	Limitation	Documentation only. No supplier's real terms were read and no tool was tested.	Every system fact comes from Projects 01-07 or from AI-A01 to AI-A04.
L-02	Limitation	Legal reading, not legal advice. The AI Act text is as amended by Regulation (EU) 2026/1744 and checked on 17 Oct 2026.	Edge questions (for example whether a meeting bot 'interacts directly' with people under Art. 50(1)) are assessor judgements. Check the Commission's Article 50 and Article 6 guidelines before relying on them.
L-03	Limitation	'No high-risk system' holds for the four recorded systems only.	The supplier AI-feature census (AIG-04) is what turns it into a company-wide statement.
L-04	Limitation	ISO/IEC 42001:2023 requirements are paraphrased. Control titles are given as short names.	Obtain the standard before implementation (AIG-15).
L-05	Limitation	Self-assessment. The same author prepared the inputs being assessed.	Same independence limit as CGI-IAU-001 (OFI-08). An independent review belongs in the ISO-12 internal audit programme.

Appendix B — Glossary

Term	Meaning
AI Act	Regulation (EU) 2024/1689, as amended by Regulation (EU) 2026/1744
AIMS	AI management system (ISO/IEC 42001)
AI RMF	NIST Artificial Intelligence Risk Management Framework 1.0
AIIA	AI system impact assessment (ISO/IEC 42001 6.1.4, A.5)
Automation bias	The tendency to trust a machine's output because a machine produced it
Deployer	Someone using an AI system under their own authority at work (Art. 3(4))
Downstream provider	A provider of an AI system that integrates someone else's AI model (Art. 3(68))
DPA	Data processing agreement (GDPR Art. 28 contract)
DPIA	Data protection impact assessment (GDPR Art. 35)
EDPB	European Data Protection Board
FRIA	Fundamental rights impact assessment (AI Act Art. 27)
GPAI	General-purpose AI (model or system)
Harmonized Structure	ISO's common clause layout for management-system standards (formerly Annex SL)
Omnibus	The Digital Omnibus on AI, Regulation (EU) 2026/1744
Provider	Whoever builds an AI system, or has it built, and puts it out under its own name (Art. 3(3))
Shadow AI	AI tools used at work without approval
SoA	Statement of Applicability
VQ-68	CGI-TPR-002 question: is our data used to train any model? Evidence: contract or signed confirmation

Source documents

- Regulation (EU) 2024/1689 (AI Act) — eur-lex.europa.eu
- Regulation (EU) 2026/1744 (Digital Omnibus on AI) — eur-lex.europa.eu
- European Commission, *AI Omnibus enters into force* — digital-strategy.ec.europa.eu
- ISO/IEC 42001:2023, *Artificial intelligence — Management system* — iso.org
- NIST, *AI Risk Management Framework 1.0* (AI 100-1) — nist.gov
- EDPB, *Guidelines on Data Protection Impact Assessment* (WP248 rev.01) — edpb.europa.eu